

REPUBLIQUE DU SENEGAL



Un peuple - Un but - Une foi

**Ministère de l'Enseignement Supérieur, de la Recherche et de l'Innovation Direction de
l'Enseignement Supérieur Privé Institut Supérieur d'Informatique**

**GROUPE
ISI**

RAPPORT DE PROJET : DirBuster

Présenté par :

Ababacar Ousmane NIANG

Sous la direction de :

MR LO

DirBuster est un outil populaire de forçage brutal de répertoires et de fichiers utilisé pour les tests de pénétration des applications web et l'évaluation des vulnérabilités. Il est conçu pour découvrir les répertoires et les fichiers cachés sur un serveur web en essayant systématiquement différents noms de répertoires et de fichiers.

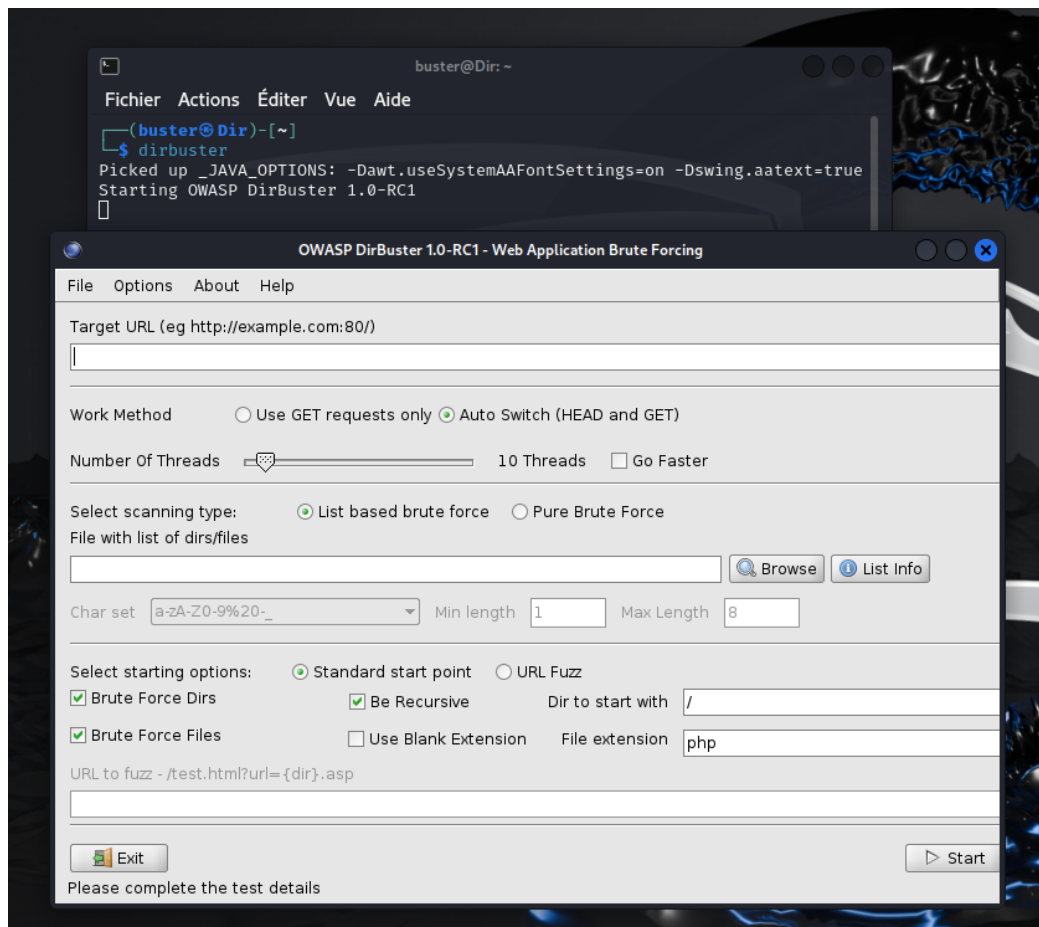
L'objectif principal de DirBuster est d'identifier les répertoires qui ne sont pas explicitement liés ou exposés sur un site web, mais auxquels un attaquant peut accéder. Ces répertoires cachés peuvent contenir des informations sensibles ou être vulnérables à divers problèmes de sécurité, tels que des configurations erronées ou des contrôles d'accès faibles.

DirBuster utilise une liste de mots ou un dictionnaire de noms de répertoires et de fichiers courants. Il envoie des requêtes HTTP au serveur web cible, en ajoutant chaque mot de la liste de mots au chemin de l'URL cible, et vérifie la réponse du serveur. Si un répertoire ou un fichier existe, DirBuster le détecte sur la base de la réponse reçue (par exemple, les codes d'état HTTP, la longueur du contenu ou les messages d'erreur).

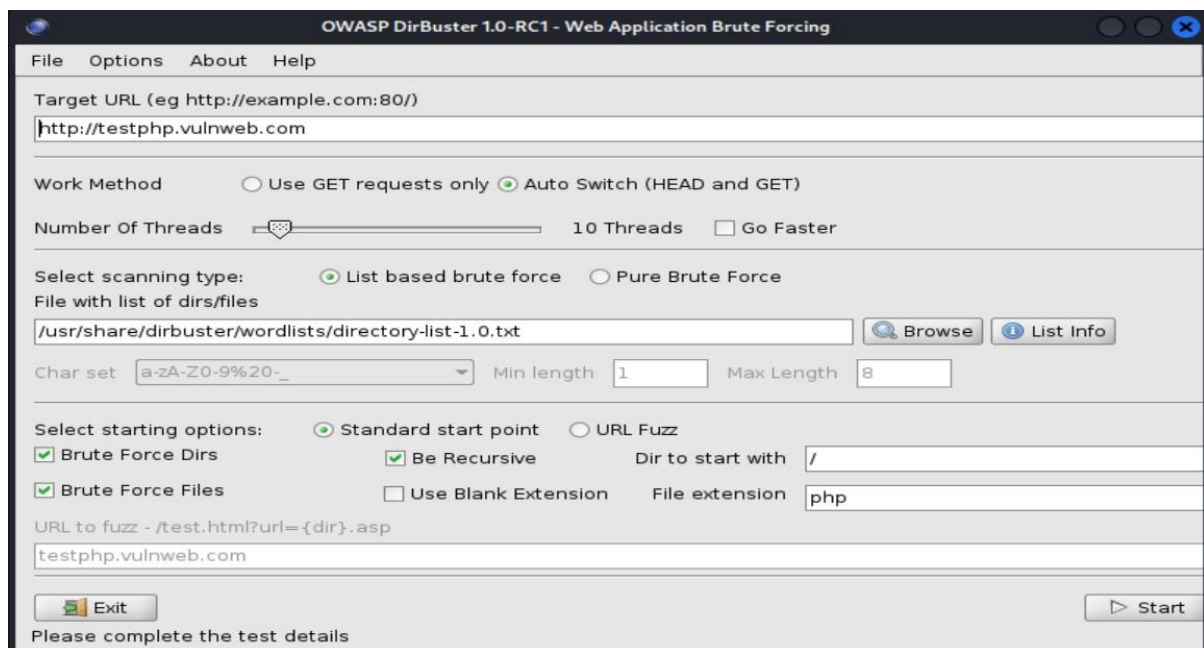
En effectuant une analyse complète de la structure des répertoires d'un serveur web, DirBuster peut aider les professionnels de la sécurité et les pirates éthiques à identifier les vulnérabilités potentielles, telles que l'accès non autorisé à des répertoires sensibles, des fichiers obsolètes ou de sauvegarde, ou des fonctionnalités cachées qui peuvent être exploitées.

Il est important de noter que DirBuster doit être utilisé de manière responsable et avec l'autorisation appropriée. L'utilisation non autorisée ou malveillante de DirBuster ou de tout autre outil similaire est illégale et peut avoir de graves conséquences. Obtenez toujours l'autorisation nécessaire et respectez les règles éthiques lorsque vous effectuez des évaluations de sécurité ou des tests de pénétration.

Avant tous, nous devons exécuter la command **DirBuster** afin d'accéder à l'interface de DirBuster.



Puis on copie le lien du site & du répertoire puis on appuis sur **start**



Ceci est la fenêtre du **Result – List View**

The screenshot shows the OWASP DirBuster 1.0-RC1 interface. The title bar reads "OWASP DirBuster 1.0-RC1 - Web Application Brute Forcing". The menu bar includes "File", "Options", "About", and "Help". The address bar shows "http://testphp.vulnweb.com:80/". The status bar indicates "Scan Information \ Results - List View: Dirs: 7 Files: 12 \ Results - Tree View \ Errors: 0 \".

Type	Found	Response	Size
Dir	/	200	5293
Dir	/cgi-bin/	403	460
File	/index.php	200	228
File	/categories.php	200	228
File	/search.php	200	228
File	/artists.php	200	228
File	/disclaimer.php	200	228
File	/cart.php	200	228
File	/guestbook.php	200	228
Dir	/AJAX/	200	228
Dir	/images/	200	155
File	/AJAX/index.php	200	228
File	/userinfo.php	302	252
File	/login.php	200	228

Current speed: 27 requests/sec (Select and right click for more options)
Average speed: (T) 27, (C) 29 requests/sec
Parse Queue Size: 0
Total Requests: 2774/2267155
Current number of running threads: 10
Time To Finish: 21:41:22
Buttons: Back, Pause, Stop, Report
Starting dir/file list based brute forcing
/Flash/quotes_of_week.php

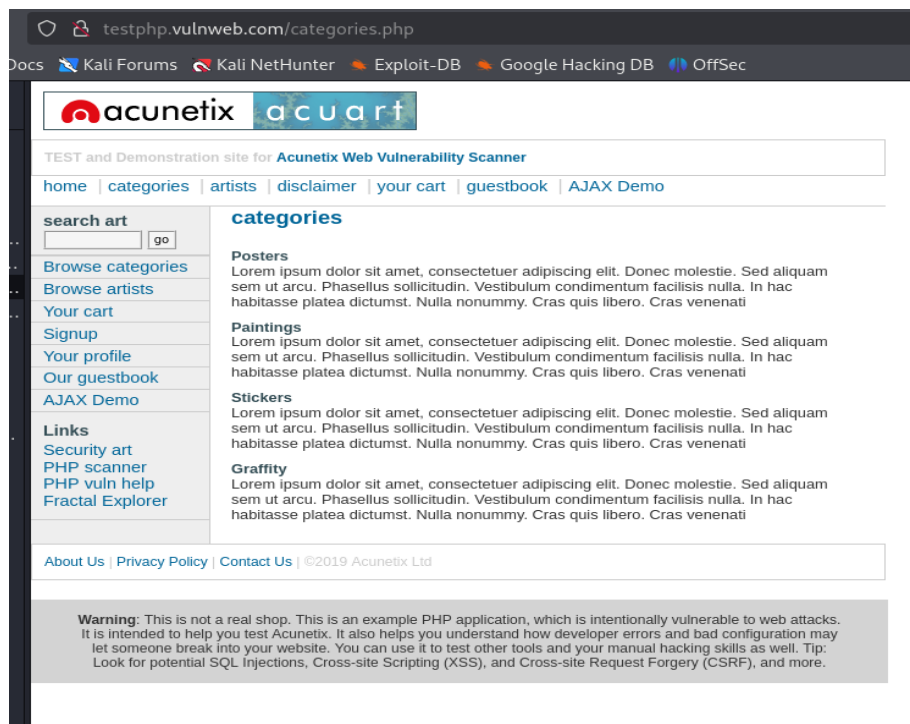
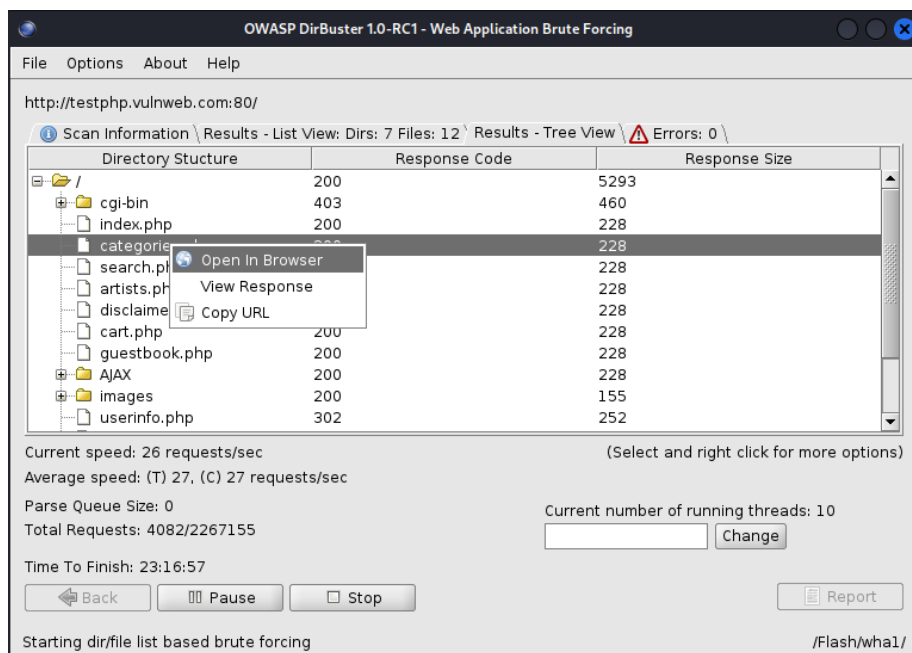
Celle-ci ,la fenêtre du **Result – Tree View**

The screenshot shows the OWASP DirBuster 1.0-RC1 interface. The title bar reads "OWASP DirBuster 1.0-RC1 - Web Application Brute Forcing". The menu bar includes "File", "Options", "About", and "Help". The address bar shows "http://testphp.vulnweb.com:80/". The status bar indicates "Scan Information \ Results - List View: Dirs: 7 Files: 12 \ Results - Tree View \ Errors: 0 \".

Directory Structure	Response Code	Response Size
/	200	5293
cgi-bin	403	460
index.php	200	228
categories.php	200	228
search.php	200	228
artists.php	200	228
disclaimer.php	200	228
cart.php	200	228
guestbook.php	200	228
AJAX	200	228
images	200	155
userinfo.php	302	252

Current speed: 28 requests/sec (Select and right click for more options)
Average speed: (T) 27, (C) 27 requests/sec
Parse Queue Size: 0
Total Requests: 3250/2267155
Current number of running threads: 10
Time To Finish: 23:17:28
Buttons: Back, Pause, Stop, Report
Starting dir/file list based brute forcing
/sportsextra.php

Clic droit sur **categories.php** puis **open in Browser**



Outil **dirbuster** : Lister les dossiers et fichiers du site :

```
root@ababacar: /home/ababacar
Fichier Actions Éditer Vue Aide
# dirb http://testphp.vulnweb.com

DIRB v2.22
By The Dark Raver

START_TIME: Fri Aug 8 22:09:44 2025
URL_BASE: http://testphp.vulnweb.com/
WORDLIST_FILES: /usr/share/dirb/wordlists/common.txt

GENERATED WORDS: 4612

--- Scanning URL: http://testphp.vulnweb.com/ ---

=> DIRECTORY: http://testphp.vulnweb.com/admin/
+ http://testphp.vulnweb.com/cgi-bin (CODE:403|SIZE:276)
+ http://testphp.vulnweb.com/cgi-bin/ (CODE:403|SIZE:276)
+ http://testphp.vulnweb.com/crossdomain.xml (CODE:200|SIZE:224)

=> DIRECTORY: http://testphp.vulnweb.com/CVS/
+ http://testphp.vulnweb.com/CVS/Entries (CODE:200|SIZE:1)
+ http://testphp.vulnweb.com/CVS/Repository (CODE:200|SIZE:8)
```